

ISEC3078 – Incident Handling & Response

Lab 2 | Threat Risk Assessment (TRA) & Incident Response Prioritization

Objective

In this lab, you will perform a **Threat Risk Assessment (TRA)** for a small organization. You will identify and value assets, analyze threats and vulnerabilities, assess risk, and use the results to **prioritize Incident Response actions** across **all assets**.

This lab demonstrates how TRA directly informs **Detect, Respond, and Recover** decisions.

Scenario

You are a cybersecurity analyst for a small organization.

Management has asked you to complete a **Threat Risk Assessment** to determine **Incident Response priorities** before an incident occurs.

Alex MacIntyre

Part 1 | Asset Identification & Valuation

Step 1: Identify Assets

Identify **at least 5 assets**.

Step 2: Assign Asset Value

Assign a qualitative and quantitative value to **each asset** using the scale below:

Value	Description
Low/50.00	Minor business impact
Medium/200.00	Operational disruption
High/5000.00	Financial, legal, or reputational impact

Asset	Value	Reason
File Server	High	Compromise of the file server can lead to severe and critical availability issues, lawsuits, fines, customer loss, and reputational damage.
Employee Laptops	Medium	A compromised laptop can stall productivity or lead to data breach without proper hardening.
Payroll System	High	When the payroll system is unavailable or compromised, it can lead to immediate financial impact, lawsuits, and fines.
Customer Database	High	Cause for lawsuits, fines, customer loss, and reputational damage.
Email System	High	An email system compromise can lead to fraudulent activity and harms the company's reputation in the event of an email leak.
Network Firewall	High	In addition to downtime that harms availability and business operations, a compromised network firewall allows for less restricted traffic and leads to high-scale data theft. This can cause major damage to customer and business relations and could be ruinous.
Test Servers	Low	Contains nothing used in production or any customer data. Compromise does not impact operations, only affecting development workflows.

Part 2 | Threats & Vulnerabilities (All Assets)

For **each asset**, identify:

- **One realistic threat** and **one vulnerability** that could be exploited

Asset	Threat	Vulnerability
File Server	Ransomware Attack	Unpatched and/or unrestricted Server Message Block (SMB) services.
Employee Laptops	Credential Attack	Lack of sufficient access control.
Payroll System	Insider Fraud	Excessive user permissions from insufficient access control.
Customer Database	SQL Injection	Poor input validation.
Email Server	Business Email Compromise	Access control, MFA policy, and poor or default email protocol configurations.
Network Firewall	Misconfiguration	Default credentials and unpatched firmware.
Test Servers	Lateral Movement	Poor network segmentation can provide a way into production environments.

Part 3 | Risk Analysis (Likelihood & Impact)

Step 1: Assign Likelihood (using this scale)

Likelihood Description

Low	Rare
Medium	Possible
High	Likely

Step 2: Assign Impact (using the above scale)

Asset	Threat	Likelihood	Impact	Risk Level
File Server	Ransomware Attack	High	High	High
Employee Laptops	Credential Attack	High	Medium	High
Payroll System	Insider Fraud	Medium	High	High
Customer Database	SQL Injection	Medium	High	High
Email System	Business Email Compromise	High	High	High
Network Firewall	Misconfiguration	Medium	High	High
Test Servers	Lateral Movement	Medium	Low	Medium

Part 4 | Incident Response Planning (All Assets)

For **each asset**, explain how Incident Response would be handled.

	Detect	Respond	Recover
	What monitoring, logging, or alerting would identify an incident?	What is the first response action if this asset is compromised?	What recovery action is required?
Asset	Detect	Respond	Recover
File Server	- Endpoint detection & response tools and anti-virus for ransomware detection. - Alerts for file encryption. - Network connectivity logs.	Isolate the network and find the source of infection.	Preserve a forensic image. Restore from most recent functional backup. Patch vulnerabilities. Review privileges and permissions.
Employee Laptops	- Alerts for unusual logins. - Authentication logs for failed login/MFA attempts.	Reset compromised credentials and isolate the device.	Perform analysis to determine any changes or access and provide a clean reimaging of the device. If needed, retrain staff on phishing.
Payroll System	- Log changes to payroll data - Monitor privileged user account access - Database monitoring for potentially unnoticed changes.	Restrict access control, communicate with finance or human resources to halt transactions.	Restore to the most recent and appropriate backup to rollback changes. Review what is being logged and if further alerts are needed. Recommend changes to segregation of duties and user privilege restrictions.
Customer Database	- Database monitoring for data exporting. - IDS detection for SQL queries from unauthorized sources. - Firewall alerts for SQL injection attempts.	Block the source of the infection and reset compromised credentials.	Perform analysis to determine which customer records were accessed. Review and assess web application security.
Email System	- Monitor email authentication logs - Alerts for domain spoofing through protocol abuse.	Block malicious addresses and reset compromised credentials. Notify the person(s) responsible for finance to be aware of	Recover the compromised accounts and assess email rules. Review phishing awareness training.

		potentially fraudulent activity.	
Network Firewall	- IDS alerts for recognized CVE patterns. - Monitor network traffic for unusual spikes. - Alerts for configuration changes. - Network monitoring for communications with production environments.	Restore to most recent backup and block internet access to administrative controls.	Harden configuration and patch vulnerabilities. Assess current firewall rules.
Test Servers	- Vulnerability scanning. - Authentication logs detailing access.	Further segment the network and disable compromised accounts.	Provide a clean reimaging of the device. Review and assess network segmentation rules. Ensure security parity with production systems.

Part 5| Incident Response Prioritization

Using your TRA results, **rank ALL assets** in order of Incident Response priority.

1. Assign a priority number to each asset:

- Priority 1 = respond first, Priority 2 = respond second, continue until all assets are ranked

2. Briefly justify why each asset has its priority level.

Asset	Risk Level	IR Priority	Justification
Customer Database	High	1	A customer database breach will lead to an immediate, catastrophic response from customers. This can cause legal, regulatory, and reputational harm to the company. Any amount of access, and every moment of prolonged access, can create an intensifyingly devastating scenario where data exfiltration could be completed and no assets were protected. This is the most harmful and immediate impact that can come of an attack on company systems.
Email System	High	2	A compromised email system from phishing and/or poor configuration can lead to deceptive impersonation and financial fraud. In addition, this can also lead to data exfiltration and ransom. The email system is necessary for communications, and when it is compromised and figures can be impersonated, it can lead to financial fraud and soured inter-business relations.

Asset	Risk Level	IR Priority	Justification
Payroll system	High	3	A compromise could lead to halted payments to staff, which is a violation of labor laws. It also disrupts employee productivity. This can create a harmful operational impact.
File Server	High	4	File server compromise can lead to the most damaging breach, with extensive consequences on all fronts. Lawsuits, fines, reputational damage, devaluation of assets, and ruptures to confidentiality, integrity, and availability. Any exposure that a malicious actor has, and each additional moment without action taken, could lead to majorly increased liability from ransomware encryption.
Network Firewall	High	5	With a compromised firewall, the layer of protection is no longer effective. While further impact can be mitigated with other control systems,
Employee Laptops	High	6	If isolated quickly, impact can be contained before the compromise can spread to other devices. The response must be as scalable as it must be prompt to be effective.
Test Servers	Medium	7	Compromised test servers containing no production information or customer data has minimal impact. Segmentation and containment must be implemented and monitored to prevent lateral movement. This is the lowest priority due to its degree of impact.
